

Kiến trúc SOA & Microservices

Đặng Ngọc Hùng

Mục lục

9. Bảo mật Microservices — OAuth 2.0, mTLS & Zero Trust	4
9.1. Các thách thức bảo mật trong kiến trúc Microservices	5
9.1.1. Vấn đề: Bề mặt tấn công (attack surface) mở rộng	5
9.1.2. Nguyên tắc “Defense in Depth”	6
9.1.3. Nâng cao: mTLS, Secrets Management, OAuth2 Scopes	7
9.2. JWT — Cấu trúc và Cơ chế	7
9.2.1. Vấn đề: Giới hạn khả năng mở rộng của phiên làm việc (session) trong microservices	7
9.2.2. JWT (JSON Web Token)	8
9.2.3. Luồng JWT mục tiêu và hiện trạng KBM	10
9.3. Tiered Trust và Xác thực theo Resource	13
9.3.1. Vấn đề: Ba phép kiểm tra thường bị gộp làm một	13
9.3.2. Hiện trạng và mục tiêu của KBM	14
9.4. OAuth2 — External Identity Provider	15
9.4.1. OAuth2 Authorization Code Flow	15
9.4.2. Nhiều phương thức xác thực	16
9.4.3. Service-to-Service: Client Credentials Flow	16
9.4.4. Không có trình duyệt: Device Authorization Grant	16
9.5. RBAC — Role-Based Access Control	17
9.5.1. Vấn đề: ai được làm gì?	17
9.5.2. Triển khai RBAC trong KBM	17
9.5.3. Bảo vệ route dựa trên API (Frontend)	18
9.6. Case Study: KBM	19
9.6.1. Phân tích tổng hợp	19
9.6.2. Đề xuất migration	20
9.6.3. Secret Management trong Production	21
9.7. Cô lập thực thi và phong tỏa (lockdown) thi cử — Hai bài học phòng thủ	24
9.7.1. Chạy mã sinh viên: rủi ro “no sandbox” và lời giải cô lập	24
9.7.2. Phong tỏa thi cử và phòng thủ chiều sâu chống gian lận	25
9.8. Tổng kết	25
9.9. Đọc thêm	26
Tài liệu tham khảo	26

CHƯƠNG 9.

Bảo mật Microservices — OAuth 2.0, mTLS & Zero Trust

“Security is not an afterthought. In a distributed system, every service is a potential attack surface.”

— Sam Newman, *Building Microservices* [4a]

MỤC TIÊU HỌC TẬP

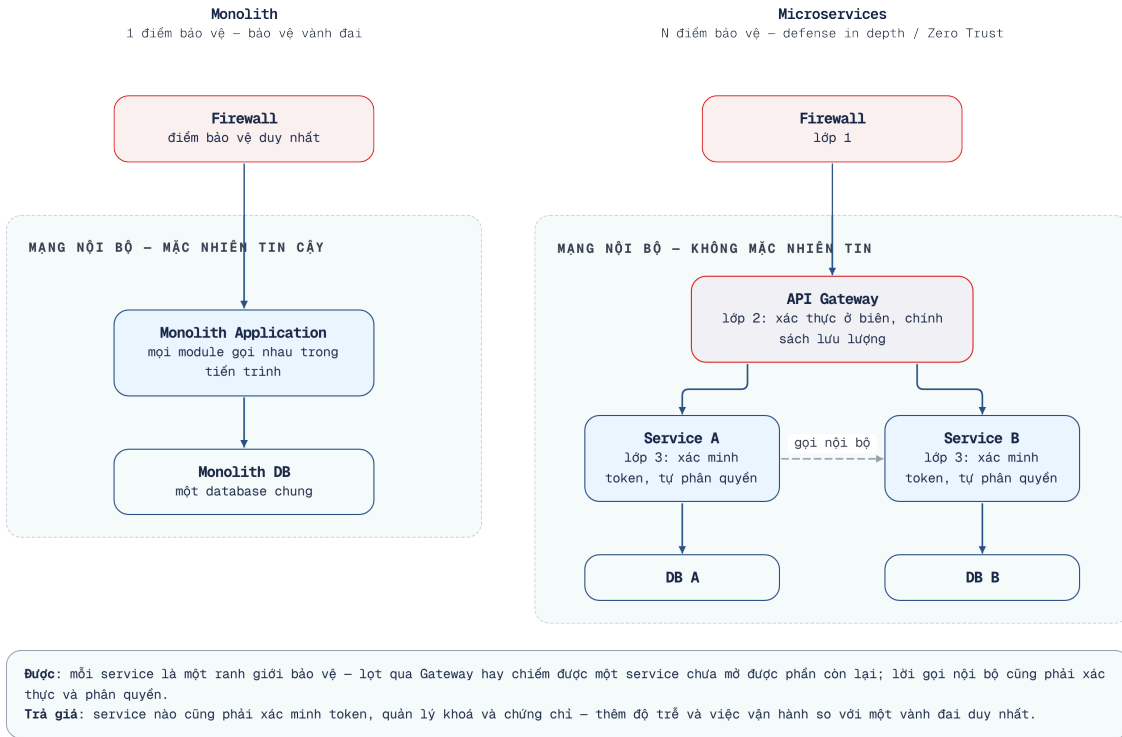
- Hiểu các thách thức bảo mật đặc thù của kiến trúc microservices
- Nắm vững cấu trúc JWT (JSON Web Token) dạng compact JWS: header, payload, signature — và phân biệt với dạng JWE nhằm phần khi cần mã hóa
- Phân biệt edge validation, resource verification và DB-based state check; áp dụng tầng tin cậy (trust tier) theo mức rủi ro
- Hiểu OAuth2/OIDC (OpenID Connect) flow và tích hợp external identity provider (Microsoft/Google)
- Thiết kế RBAC (Role-Based Access Control) cho hệ thống đa vai trò
- Tách biệt user subject, calling workload/actor và delegation trong giao tiếp service-to-service
- Phân tích kiến trúc bảo mật của KBM

9.1. Các thách thức bảo mật trong kiến trúc Microservices

Việc đảm bảo an ninh cho một hệ thống nguyên khối giống như bảo vệ một pháo đài duy nhất, nhưng với microservices, bài toán này biến thành việc phải bảo vệ từng tòa nhà, từng giảng đường nằm rải rác khắp khuôn viên đại học.

9.1.1. Vấn đề: Bề mặt tấn công (attack surface) mở rộng

Trong kiến trúc nguyên khối (monolith), bảo mật tập trung tại một điểm: một ứng dụng, một cơ sở dữ liệu, một tầng xác thực (authentication layer). Khi chuyển sang microservices, bề mặt tấn công (attack surface) mở rộng tỷ lệ thuận với số lượng dịch vụ:



Hình 9.1: Monolith (1 điểm bảo vệ) vs Microservices (N điểm bảo vệ)

Sam Newman trong cuốn **Building Microservices** đã liệt kê ra năm thách thức bảo mật đặc thù khi chuyển dịch sang hệ thống phân tán, nơi sự tin tưởng mặc định không còn tồn tại và mỗi thành phần đều phải tự thiết lập cơ chế bảo vệ:

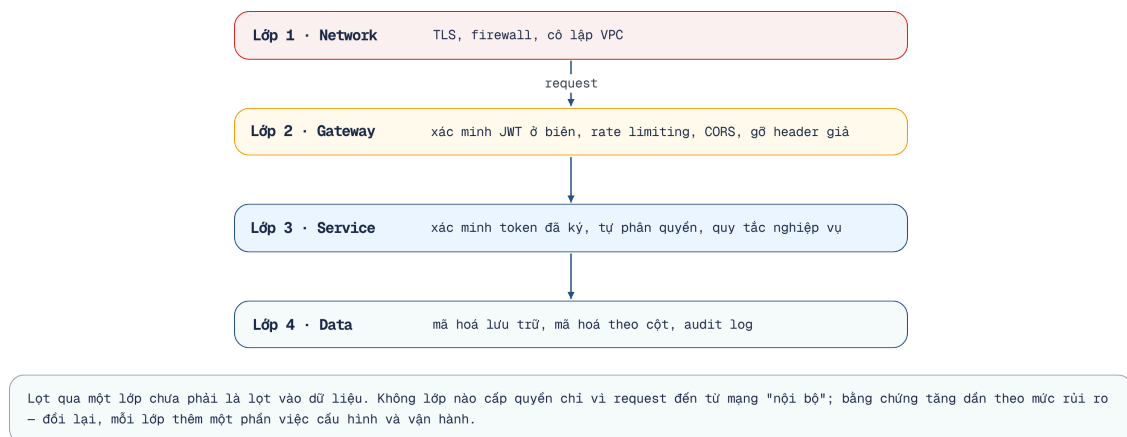
#	Thách thức	Monolith	Microservices
1	Xác thực	Một session store	Gateway kiểm tra credential ở biên; resource service xác minh bằng chứng (proof) phù hợp với trust tier
2	Phân quyền	Kiểm tra cục bộ (in-process)	Mỗi dịch vụ cần phải kiểm tra quyền truy cập — người dùng được phép thực hiện những hành động nào?

#	Thách thức	Monolith	Microservices
3	Service-to-service trust	Không có (in-process)	Dịch vụ B phải phân biệt workload A đang gọi, user subject (nếu có) và quyền delegation
4	Data in transit	Nội bộ (in-process)	Lời gọi mạng — cần mã hóa (TLS)
5	Secret management	Một file cấu hình	N dịch vụ kết hợp với M thông tin xác thực (secrets) = bài toán quản lý phức tạp

Bảng 9.1: Năm thách thức bảo mật đặc thù khi chuyển từ monolith sang microservices

9.1.2. Nguyên tắc “Defense in Depth”

Để đối phó với những thách thức phức tạp đa chiều, bảo mật trong môi trường phân tán bắt buộc phải dựa trên triết lý **defense in depth** (phòng thủ chiều sâu). Thay vì chỉ phụ thuộc vào một tường lửa duy nhất ở biên mạng, chúng ta phải xây dựng nhiều rào chắn bảo vệ nối tiếp nhau từ tầng mạng cho đến tận tầng dữ liệu:



Hình 9.2: Defense in Depth — bảo vệ nhiều lớp từ tầng mạng đến tầng dữ liệu

Trong thực tế, mức độ bảo vệ tùy thuộc vào **trust boundary**, nhưng vị trí trong private network/VPC không tự biến request thành đáng tin cậy. Gateway tạo một ranh giới vào (ingress) quan trọng; mỗi service đích vẫn là một ranh giới tài nguyên (resource boundary) vì service có dữ liệu và quy tắc authorization riêng.

Tin cậy phân tầng (Tiered Trust), không chỉ tin cậy ở biên

Zero Trust không có nghĩa là lặp lại truy vấn database ở mọi hop; nó yêu cầu không cấp quyền chỉ vì request đến từ một vị trí mạng được xem là “nội bộ”. Thiết kế thực dụng là tăng bằng chứng theo mức rủi ro: làm sạch request ở biên (ingress sanitation), signed proof đúng audience, local authorization, rồi bổ sung workload identity hoặc delegation khi cần.

Sách sử dụng bốn tầng tin cậy (trust tier) thống nhất. **Tier 0** là request ngoài chưa được tin cậy: Gateway phải làm sạch header và xác minh token. **Tier 1** là luồng nội bộ thông thường: resource service xác minh signed identity proof và tự phân quyền. **Tier 2** áp dụng cho nghiệp vụ nhạy cảm: ngoài user subject còn

phải nhận diện calling workload/actor và delegation. **Tier 3** dành cho job hoặc command bất đồng bộ: consumer xác minh workload cùng quyền thực thi của job/command, không giả định rằng message broker đã tạo ra sự tin cậy.

9.1.3. Nâng cao: mTLS, Secrets Management, OAuth2 Scopes

Khi hệ thống mở rộng quy mô (scale) hoặc mức độ rủi ro (risk profile) tăng lên (ví dụ: bổ sung phân hệ thanh toán, xử lý dữ liệu cá nhân), cần nâng cấp các biện pháp bảo mật:

mTLS (Mutual TLS) — Trong TLS thông thường, chỉ có máy khách xác thực máy chủ (ví dụ trình duyệt xác thực chứng chỉ HTTPS). Trong mTLS, **cả hai bên đều xác thực lẫn nhau**: Khi Dịch vụ A gọi Dịch vụ B, B kiểm tra chứng chỉ của A và A kiểm tra chứng chỉ của B. Cơ chế này bảo vệ kênh truyền và chứng thực workload ở hai đầu kết nối.

Khác với giao tiếp nội bộ qua HTTP không mã hóa, mTLS giảm nguy cơ nghe lén và giả mạo workload. Tuy nhiên, chứng chỉ của service A không chứng minh rằng claim `userId` do A chuyển tiếp là đúng; user subject vẫn cần signed proof hoặc delegation có thể xác minh. Nhược điểm đánh đổi là độ phức tạp của cấp phát, luân phiên và thu hồi chứng chỉ, thường cần công cụ như cert-manager hoặc service mesh.

Trong KBM, mTLS chưa được xác nhận là đã triển khai. Đây là khoảng trống chấp nhận tạm thời trong hiện trạng học thuật, không phải lý do để coi mạng nội bộ là identity proof. Khi mức độ rủi ro tăng, mTLS cùng NetworkPolicy giúp thu hẹp khả năng di chuyển ngang (lateral movement); signed user proof và local authorization vẫn là các lớp độc lập.

Secrets Management — Thông tin xác thực (Credentials như mật khẩu cơ sở dữ liệu, khóa API, khóa bí mật JWT) không nên được lưu trữ trực tiếp trong mã nguồn hoặc ảnh (images) Docker:

Trong việc quản lý thông tin nhạy cảm, gán cứng (hardcode) secrets trực tiếp vào mã nguồn (như `password: "abc123"`) là mức rủi ro cao nhất: một khi đã commit, chúng nằm lại vĩnh viễn trong lịch sử Git.

Cấp độ bảo mật trung bình là sử dụng biến môi trường (environment variables) qua file `.env`, phương án này tách bạch mã nguồn khỏi cấu hình nhưng vẫn dễ bị đánh cắp nếu kẻ gian rà quét tiến trình chạy container. Giải pháp tiêu chuẩn cho hệ thống production là sử dụng các hệ thống quản lý bí mật chuyên dụng (Secrets Manager) như HashiCorp Vault, cung cấp cơ chế mã hóa tĩnh, tự động xoay vòng khóa và kiểm toán truy cập.

KBM hiện đang sử dụng các biến môi trường (environment variables) ở một số môi trường triển khai (đáp ứng đủ quy mô của phạm vi học thuật) — tuy nhiên, khóa bảo mật JWT cần được luân phiên (rotate) định kỳ và tuyệt đối không lưu trữ (commit) trực tiếp vào mã nguồn.

OAuth2 Scopes — Hiện tại RBAC của KBM dùng các vai trò (STUDENT, LECTURER, ADMIN). OAuth2 scopes mở rộng: thay vì “user có role ADMIN”, phạm vi quyền (scope) cho phép chỉ định “ứng dụng máy khách X có quyền đọc bài nộp nhưng không có quyền ghi điểm”. Cơ chế này đặc biệt phù hợp khi KBM cung cấp API cho các bên thứ ba (như ứng dụng di động độc lập hoặc tích hợp với các hệ thống khác).

9.2. JWT — Cấu trúc và Cơ chế

Khi số lượng sinh viên truy cập đồng thời vào hệ thống thư viện tăng vọt, việc duy trì một số điểm danh tập trung sẽ nhanh chóng bộc lộ nhiều điểm yếu. Khác với mô hình cũ, hệ thống cần một phương thức kiểm tra thẻ độc lập, phi tập trung hơn để phân tán áp lực xác thực.

9.2.1. Vấn đề: Giới hạn khả năng mở rộng của phiên làm việc (session) trong microservices

Trong kiến trúc nguyên khối, quá trình xác thực thường sử dụng cơ chế phiên làm việc phía máy chủ (**server-side session**): Người dùng đăng nhập, máy chủ tạo một phiên làm việc, lưu trữ trong bộ nhớ hoặc

Redis, sau đó trả về mã định danh phiên (session ID) dưới dạng cookie. Các yêu cầu tiếp theo sẽ gửi kèm cookie này để máy chủ tra cứu và nhận diện người dùng.

Trong kiến trúc microservices, kho lưu trữ phiên (session store) tạo ra một điểm phụ thuộc tập trung (**centralized dependency**): việc mọi dịch vụ phải truy vấn cùng một cơ sở dữ liệu phiên sẽ gây ra hiện tượng thắt cổ chai và tạo thành điểm nghẽn duy nhất (single point of failure). Ngược lại, nếu mỗi dịch vụ có một kho lưu trữ phiên riêng, người dùng sẽ phải đăng nhập lại mỗi khi chuyển đổi giữa các dịch vụ.

9.2.2. JWT (JSON Web Token)

🔗 Thi Giấy vs Thi Máy Tính

Session (Thi giấy) – Giám thị phải mang theo một danh sách điểm danh. Mỗi khi có sinh viên nộp bài, giám thị phải tra đúng dòng, đúng tên trong danh sách (Lookup session store). Nếu giám thị chuyển danh sách đi phòng khác, hệ thống sẽ rối loạn.

JWT (Thi máy tính) – Giống như một **Mã QR định danh** do Hệ thống Khảo thí cấp khi đăng nhập. Sinh viên cầm mã QR này nộp bài. Hệ thống chấm bài (Service) chỉ cần quét xem mã QR có chữ ký điện tử hợp lệ của phòng Khảo thí không, tự giải mã được mã SV mà không cần truy vấn vào cơ sở dữ liệu.

JWT giải quyết vấn đề này bằng cách đóng gói (encode) thông tin định danh (identity information) vào *chính token* kèm chữ ký số – phi trạng thái (stateless), không cần kho lưu trữ phiên (session store) [4a, Ch.9]:

```
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.    ← Header
eyJ1c2VySWQiOiJ1c2VyLTZyMyIsInR5cCI6IkpXVCJ9.    ← Payload
VREOVVF9BRE1JTlIsImV4cCI6MTcxMDAwMDAwMH0.
SflKxwRJSMeKKf2QT4fwpMeJf36POk6yJV_adQssw5c    ← Signature
```

Ba phần của một JWT dạng compact JWS:



Hình 9.3: Cấu trúc JWT dạng compact JWS – Header, Payload, Signature

Về mặt cấu trúc, JWT minh họa ở đây là *compact JWS* – dạng phổ biến nhất – gồm ba mảnh được encode Base64URL riêng biệt (JWT dạng JWE mã hóa có năm mảnh). Phần đầu tiên là **Header** chứa thông tin về thuật toán ký và loại token (ví dụ: `{"alg": "HS256"}`). Phần thứ hai là **Payload**, mang theo các dữ liệu định danh (claims) đặc biệt quan trọng của người dùng như `userId` hay `roles`. Thành phần cuối cùng là **Signature**, bảo vệ tính toàn vẹn của token bằng cách ký lên Header và Payload – HS256 dùng HMAC với khóa bí mật, RS256 ký bằng private key (bảng so sánh bên dưới) – giúp ngăn chặn việc chỉnh sửa dữ liệu trái phép.

Cần lưu ý rằng Base64URL chỉ là *encoding*, không phải mã hóa: bất kỳ ai cầm token đều đọc được toàn bộ payload. Vì vậy tuyệt đối không đặt mật khẩu hay dữ liệu nhạy cảm trong claims; khi thật sự cần giữ bí mật nội dung, hãy dùng JWE (JSON Web Encryption), lược bỏ claim nhạy cảm khỏi payload, hoặc chuyển sang opaque token – tùy mô hình mối đe dọa (threat model).

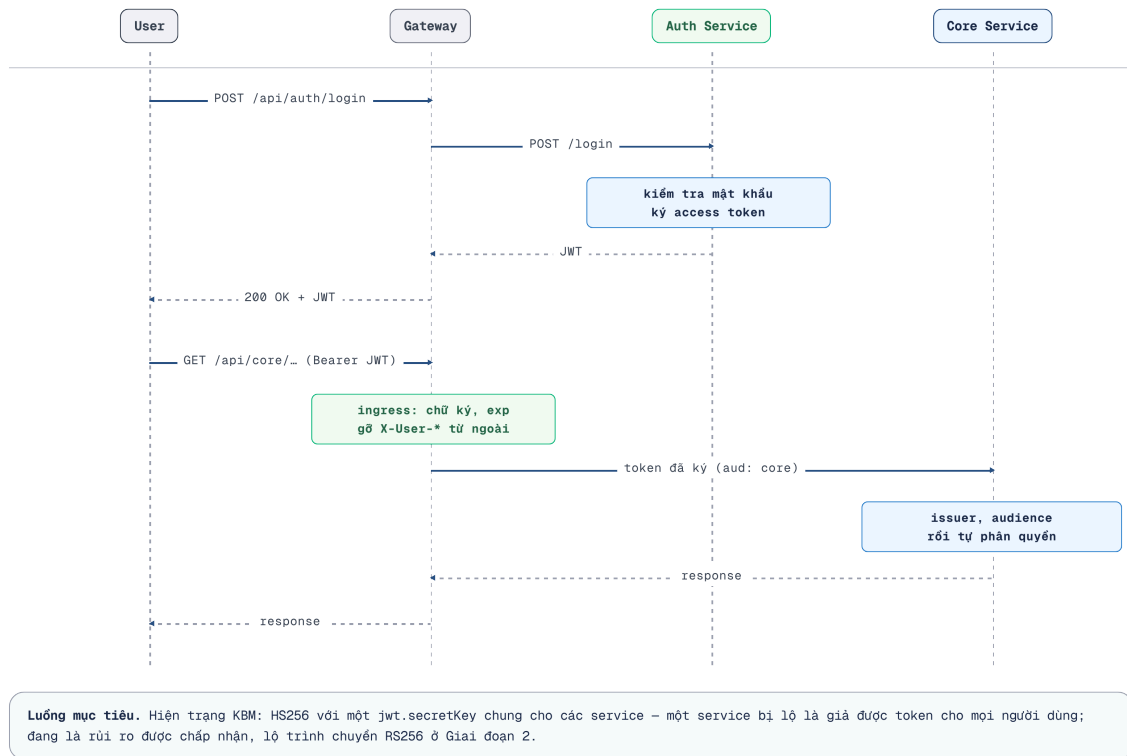
So sánh HS256 và RS256: Hai thuật toán phổ biến này có một số điểm khác biệt quan trọng trong việc thiết lập và xác minh chữ ký:

	HS256 (đối xứng)	RS256 (bất đối xứng)
Khóa	Khóa bí mật dùng chung (Shared secret key)	Khóa riêng tư (ký) + Khóa công khai (xác minh)
Thực hiện ký?	Dịch vụ Xác thực (có khóa bí mật)	Dịch vụ Xác thực (có khóa riêng tư)
Thực hiện xác minh?	Bất kỳ dịch vụ nào có khóa bí mật	Bất kỳ dịch vụ nào có khóa công khai
Bảo mật	Nếu khóa bí mật (secret key) bị lộ, cả quá trình ký và xác thực đều bị xâm phạm	Khóa công khai phân phối rộng rãi không gây rủi ro; nhưng nếu khóa riêng tư (private key) bị lộ, kẻ tấn công ký được token giả mà mọi dịch vụ vẫn xác minh “hợp lệ” — phải thu hồi và xoay khóa khẩn cấp
Luân phiên khóa	Phải phân phối an toàn secret mới cho mọi bên xác minh (verifier)	Auth Service công bố public keys mới qua JWKS; verifier tự làm mới cache
Phù hợp khi	Phạm vi hẹp, ít verifier và kiểm soát secret chặt	Nhiều resource server/verifier; chỉ issuer giữ private key

Bảng 9.2: HS256 (đối xứng) vs RS256 (bất đối xứng)

Dù dùng HS256 hay RS256, resource server không được suy ra tính hợp lệ chỉ từ việc decode thành công. Hợp đồng xác minh tối thiểu phải khóa thuật toán được phép, kiểm tra signature, đối chiếu chính xác issuer và audience, rồi kiểm tra `exp` cùng `nbf` trước khi dùng claims để authorize. Token dành cho Gateway không mặc nhiên hợp lệ ở mọi dịch vụ tuyến sau (downstream service); nếu audience khác nhau, cần token exchange hoặc internal token riêng.

9.2.3. Luồng JWT mục tiêu và hiện trạng KBM



Hình 9.4: Luồng JWT mục tiêu — ingress validation, signed proof và local authorization

❗ KBM dùng HS256 với shared secret

KBM sử dụng HS256 (symmetric) — các dịch vụ chia sẻ cùng `jwt.secretKey`. Đây là rủi ro đáng kể: nếu bất kỳ dịch vụ nào bị xâm nhập, kẻ tấn công có thể tạo lập chuỗi JWT giả mạo cho **bất kỳ người dùng nào trên toàn hệ thống** (không giới hạn ở dịch vụ bị tấn công). Với KBM học thuật, đây là **rủi ro được chấp nhận (accepted risk) hiện tại** cần được ghi rõ, không phải mô hình mục tiêu cho production. **Lộ trình chuyển đổi** được xếp vào Giai đoạn 2 vì cần hạ tầng quản lý khóa: (1) Auth Service chuyển sang RS256 và là nơi duy nhất giữ private key; (2) các resource service dùng Spring Security OAuth2 Resource Server để xác minh theo cùng issuer/audience; (3) public keys được luân phiên qua JWKS; (4) Gateway phát hành hoặc trao đổi sang internal token đúng audience khi không thể chuyển tiếp external token nguyên trạng.

Việc luân phiên khóa (key rotation) trong thực tế vướng một rào cản kỹ thuật cụ thể.

❗ Cửa sổ dual-secret khi luân phiên khóa HS256

Luân phiên (rotate) khóa bí mật của HS256 không thể thực hiện tức thời: nếu Dịch vụ Xác thực chuyển sang khóa bí mật mới trong khi các dịch vụ khác vẫn giữ khóa bí mật cũ, mọi token đang lưu hành sẽ ngay lập tức bị xác minh thất bại. Cách an toàn là duy trì một **cửa sổ dual-secret**: trong giai đoạn chuyển tiếp, khâu *xác minh* của các dịch vụ sẽ chấp nhận **cả khóa cũ lẫn khóa mới** (**current** + **previous**), còn Dịch vụ Xác thực sẽ ký bằng khóa mới; chỉ gỡ bỏ khóa cũ sau khi mọi token được ký bằng nó đã hoàn toàn hết hạn. Sự phức tạp này là một lý do nữa để chuyển sang cơ chế RS256/JWKS — khi đó chỉ cần công bố thêm khóa công khai mới qua endpoint JWKS, không cần phải đồng bộ khóa bí mật qua tất cả các dịch vụ.

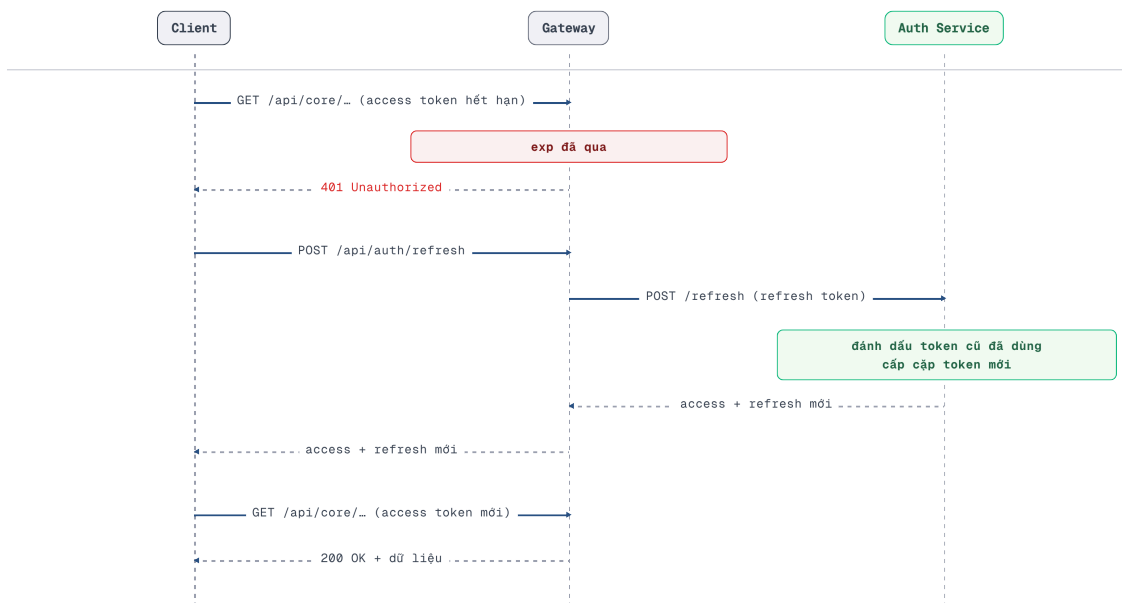
Ảnh dụ: Đăng ký vé dùng máy tính Thư viện

Access Token — là **Vé sử dụng máy tính thư viện 1 giờ** (ngắn hạn để nếu lộ thông tin vé, kẻ gian chỉ sử dụng được 1 giờ).

Refresh Token — là **Thẻ Sinh Viên gốc**, dùng để xuất trình cho Thủ thư cấp vé 1 giờ mới khi hết hạn.

Token Rotation — mỗi lần xin vé, Thủ thư dán **tem gia hạn mới** lên thẻ và hủy hiệu lực tem cũ — refresh token vì thế đổi mới sau mỗi lần dùng. Nếu kẻ gian dùng lại tem cũ đã hủy, hệ thống phát hiện ngay và **thu hồi toàn bộ chuỗi tem** của thẻ đó.

JWT có thời hạn (**exp**). Khi access token hết hạn, người dùng phải **xác thực lại (re-authenticate)** — làm giảm trải nghiệm người dùng đối với các phiên làm việc kéo dài (ví dụ: giảng viên sử dụng hệ thống liên tục suốt một buổi giảng). **Refresh token** giải quyết bài toán này: access token có thời hạn ngắn (15–60 phút), còn refresh token có thời hạn dài hơn (7–30 ngày). Khi access token hết hạn, client dùng refresh token để nhận access token mới — không cần đăng nhập lại.



Rotation: mỗi refresh token chỉ dùng được một lần. Ai dùng lại token đã dùng, Auth coi như bị đánh cắp — thu hồi cả chuỗi token (family) và buộc đăng nhập lại.

Hình 9.5: Luồng làm mới và luân phiên token — access token mới + refresh token mới

Token Rotation là chiến lược luân phiên quan trọng: mỗi lần refresh token được sử dụng, **bản thân nó cũng được thay mới** và bản cũ bị vô hiệu hóa. Lợi ích của cơ chế này là: nếu refresh token bị đánh cắp và dùng lại trái phép, Auth Service sẽ phát hiện token đó đã qua sử dụng. Khi đó, hệ thống sẽ tự động vô hiệu hóa toàn bộ chuỗi token liên quan và buộc người dùng phải đăng nhập lại từ đầu [4a, Ch.9].

```
// Auth Service — Token refresh với rotation
// @Transactional: đánh dấu token cũ đã dùng + phát hành token mới trong CÙNG transaction.
// noRollbackFor: lệnh thu hồi family phải được COMMIT ngay cả khi chúng ta chủ động ném
// TokenReuseException để từ chối request (mặc định Spring rollback theo RuntimeException)
@Transactional(noRollbackFor = TokenReuseException.class)
@PostMapping("/refresh")
public TokenResponse refreshToken(@RequestBody RefreshRequest request) {
    RefreshToken stored = refreshTokenRepository
        .findByToken(request.getRefreshToken())
        .orElseThrow(() -> new AuthException("Invalid refresh token"));

    // Kiểm tra hết hạn
    if (stored.isExpired()) {
        throw new AuthException("Refresh token expired");
    }

    // Cập nhật atomic
    int updatedRows = refreshTokenRepository.markAsUsedAtomic(stored.getId());
    if (updatedRows == 0) {
        // Phát hiện việc sử dụng lại token! Tiến hành vô hiệu hóa toàn bộ chuỗi token
        refreshTokenRepository.invalidateFamily(stored.getFamily());
        throw new TokenReuseException("Token reuse detected — please login again");
    }

    // Phát hành cặp token mới thuộc cùng một chuỗi (family)
    User user = stored.getUser();
    String newAccessToken = jwtUtil.generateAccessToken(user); // 30 phút
    String newRefreshToken = createRefreshToken(user, stored.getFamily()); // 7 ngày

    return new TokenResponse(newAccessToken, newRefreshToken);
}
```

Listing 9.1: Endpoint làm mới token có luân phiên (rotation)

Có ba chi tiết triển khai dễ bị bỏ sót. Thứ nhất, ví dụ trên lưu token thô cho dễ đọc, còn production nên lưu *hash* của refresh token (tương tự cách lưu mật khẩu) và so khớp qua hash.

Thứ hai, cặp thao tác “đánh dấu token cũ đã dùng — phát hành token mới” phải nằm trong cùng một transaction. Riêng nhánh phát hiện reuse thì lệnh thu hồi family phải được **commit** chứ không bị rollback theo exception từ chối request — đó là lý do có `noRollbackFor` trong ví dụ; phương án khác là tách việc thu hồi vào một transaction `REQUIRES_NEW`.

Thứ ba, khi hai yêu cầu làm mới hợp lệ chạy song song, yêu cầu thua cuộc sẽ kích hoạt nhằm cảnh báo reuse. Hệ thống cần một chính sách rõ ràng cho tình huống này, chẳng hạn một khoảng ân hạn ngắn, để không vô hiệu hóa nhầm token vừa cấp.

Chiến lược này yêu cầu thiết lập độ dài thời gian sống (TTL) khác biệt cho từng loại token:

Token	Thời hạn	Lưu ở đâu	Lý do
Access token	15-60 phút	Bộ nhớ client/cookie	Thời gian sống ngắn giúp giảm thiểu rủi ro nếu token bị rò rỉ

Token	Thời hạn	Lưu ở đâu	Lý do
Refresh token	7-30 ngày	HttpOnly cookie + DB	Thời gian sống dài duy trì trải nghiệm liền mạch, lưu ở DB để có thể thu hồi
Token family	Theo refresh token	DB (family ID)	Giúp phát hiện việc tái sử dụng trái phép và thu hồi toàn bộ chuỗi

Bảng 9.3: Access token, refresh token và token family — thời hạn, nơi lưu trữ và lý do thiết kế

9.3. Tiered Trust và Xác thực theo Resource

Bài toán không phải chọn một trong hai cực “mọi service đều truy vấn cơ sở dữ liệu” hoặc “chỉ Gateway xác thực”. Cần tách ba thao tác: Gateway kiểm tra credential ở ingress; resource service xác minh signed proof dành cho mình; chỉ những luồng cần trạng thái mới truy vấn Auth Service hoặc revocation store.

🔗 Cổng trường, giấy giới thiệu và phòng chức năng

Gateway giống trạm kiểm soát cổng trường – kiểm tra credential ngoài, loại bỏ giấy tờ do người vào tự sửa và chỉ cho request hợp lệ đi tiếp.

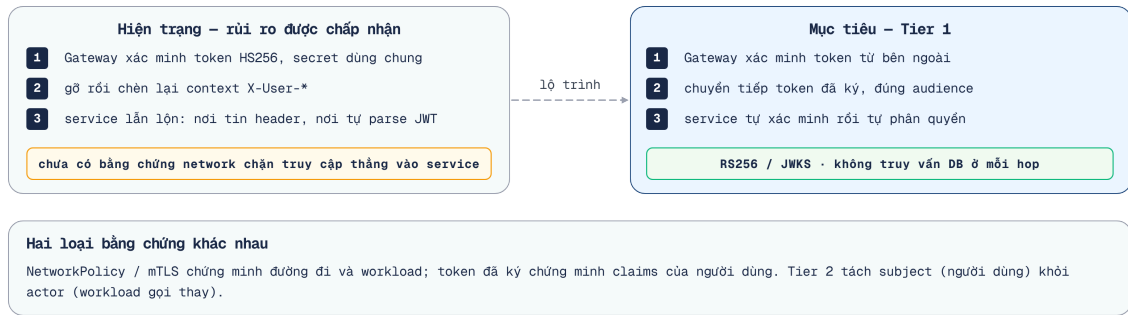
Resource service giống phòng chức năng – kiểm tra con dấu cùng tên phòng nhận trên giấy giới thiệu, rồi tự quyết định người đó có quyền xem bảng điểm, sửa đề hay duyệt kết quả hay không. Với nghiệp vụ nhạy cảm, phòng còn kiểm tra người mang giấy đang đại diện cho ai.

9.3.1. Vấn đề: Ba phép kiểm tra thường bị gộp làm một

Xác minh mật mã (cryptographic verification) kiểm tra thuật toán, chữ ký, issuer, audience và thời hạn; thao tác này stateless và không đòi hỏi truy vấn cơ sở dữ liệu. **Kiểm tra trạng thái (state check)** hỏi tài khoản còn hoạt động hay token đã bị thu hồi; nó chỉ cần ở login, refresh hoặc thao tác nhạy cảm theo chính sách. **Authorization** là quyết định nghiệp vụ trên resource cụ thể và luôn thuộc service sở hữu resource.

Nếu chỉ Gateway kiểm tra rồi thay token bằng `X-User-*`, service đích không còn bằng chứng mật mã khi có route bypass hoặc workload bị chiếm quyền. Ngược lại, nếu mỗi service tự viết verifier và tự truy vấn cơ sở dữ liệu người dùng ở mọi request, logic vừa trùng lặp vừa tạo coupling. Tiered Trust giữ resource verification nhưng chuẩn hóa nó qua framework, issuer metadata và JWKS.

9.3.2. Hiện trạng và mục tiêu của KBM



Hình 9.6: Luồng định danh KBM — rủi ro được chấp nhận hiện tại và mục tiêu Tier 1

Tầng	Ranh giới	Bằng chứng	Quyết định tại service đích
T0	Client ngoài → Gateway	External token; sanitize mọi identity header	Gateway kiểm tra alg, signature, iss, aud, exp, nbf
T1	Gateway/service → resource service	Signed token hoặc metadata đúng audience	Xác minh proof rồi local authorization
T2	Luồng nhảy cảm service-to-service	User subject + workload/actor + delegation; mTLS khi phù hợp	Giới hạn cả quyền người dùng lẫn quyền workload
T3	Producer/job → broker → consumer	Workload identity + quyền job/command + freshness	Consumer xác minh context và authorize command

Bảng 9.4: Bốn tầng tin cậy dùng xuyên suốt sách

Hiện trạng — accepted risk: Gateway xác minh HS256, loại bỏ rồi chèn lại X-User-Id / X-User-Roles; Core, Judge và Academic đang lẫn lộn giữa header-trust và tự parse JWT. Bằng chứng cấu hình rằng mọi đường gọi trực tiếp đã bị chặn vẫn chưa hoàn chỉnh. Vì vậy sách không gọi hiện trạng này là Zero Trust hay defense in depth.

Mục tiêu Tier 1: Gateway xác minh token ngoài, giữ signed proof trong giai đoạn chuyển tiếp hoặc token exchange sang internal token đúng audience. Mỗi resource service dùng verifier chuẩn hóa để kiểm tra proof và tự authorize. Auth Service chỉ thực hiện DB-based state check ở login, refresh, revocation hoặc thao tác nhảy cảm; không có yêu cầu truy vấn cơ sở dữ liệu ở mọi hop.

⚠️ Bảo mật Header và Truyền định danh (Identity Propagation)

Gateway bắt buộc phải loại bỏ mọi `X-User-*` do client gửi trước khi dẫn xuất context mới. Tuy nhiên, việc làm sạch header chỉ chặn spoofing tại ingress; một plain header vẫn không phải identity proof. Service đích chỉ được ra quyết định dựa trên signed token/metadata đã kiểm tra issuer, audience và freshness. NetworkPolicy giới hạn đường đi; mTLS chứng thực workload; hai lớp này không thay thế chữ ký cho user claims.

Với Machine-to-Machine, Client Credentials đại diện cho **calling workload/actor**, không tự tạo ra user subject. Nếu service gọi thay mặt người dùng, proof phải mang subject và actor/delegation tách biệt để service đích giới hạn đồng thời quyền của cả hai. Job không có người dùng thì không được tự gắn `X-User-Id` giả để mượn quyền người dùng.

Gateway chịu trách nhiệm authentication ở ingress nhưng không sở hữu toàn bộ quyết định tin cậy. Resource service xác minh proof tại boundary của mình và chịu trách nhiệm authorization nghiệp vụ. Sự phân công này giữ business rules ngoài Gateway mà không buộc service tin mù quáng vào vị trí mạng hoặc định dạng header.

9.4. OAuth2 — External Identity Provider

Ủy quyền xác thực (Delegated Authentication) cho các nhà cung cấp định danh bên ngoài giúp giảm thiểu rủi ro bảo mật từ việc tự quản lý mật khẩu, đồng thời mang lại trải nghiệm SSO liền mạch cho người dùng.

Vấn đề quản lý thông tin đăng nhập (credentials): Tự quản lý thông tin đăng nhập đòi hỏi phải xử lý nhiều nghiệp vụ phức tạp: bấm mật khẩu (hash passwords), cấp lại mật khẩu đã quên, xác thực đa yếu tố (2FA), chống tấn công dò mật khẩu (brute force protection) và tuân thủ các quy chuẩn bảo mật. Với đội ngũ nhỏ, **ủy quyền xác thực (delegate authentication)** cho identity provider chuyên nghiệp (Google, Microsoft, GitHub) giúp giảm đáng kể công sức và rủi ro.

9.4.1. OAuth2 Authorization Code Flow

🔑 Đăng ký Ký túc xá bằng tài khoản Cổng đào tạo

Hãy tưởng tượng Ban quản lý Ký túc xá cần xác nhận một sinh viên đang theo học trước khi xếp phòng. Ký túc xá (Client) không được phép hỏi mật khẩu Cổng thông tin đào tạo của sinh viên (rất nguy hiểm). Thay vào đó, Ký túc xá chuyển hướng sinh viên sang Cổng đào tạo của trường để tự đăng nhập. Sau khi đăng nhập, trường cấp cho sinh viên một “Phiếu xác nhận” (Authorization Code) chỉ dùng được 1 lần. Hệ thống backend của Ký túc xá mang phiếu đó đến thẳng Phòng Đào tạo để đổi lấy “Giấy phép tra cứu hồ sơ” (Token) — có thời hạn và chỉ cho xem đúng những thông tin cần để xếp phòng.

KBM tích hợp OAuth2/OIDC để thực hiện đăng nhập thông qua nhà cung cấp danh tính của trường (ví dụ: Microsoft Entra ID hoặc Google Workspace). Quy trình hoạt động như sau: Người dùng được chuyển hướng tới hệ thống cung cấp danh tính để đăng nhập. Khi thành công, hệ thống nhận về mã ủy quyền (authorization code) qua callback. Tiếp đó, Dịch vụ Xác thực sử dụng mã này để đổi lấy token thông qua giao tiếp trực tiếp giữa các máy chủ (server-to-server). Cuối cùng, dịch vụ truy xuất thông tin người dùng, tìm kiếm hoặc tạo mới tài khoản tương ứng và phát hành chuỗi KBM JWT nội bộ.

Điểm quan trọng: KBM *không sử dụng* trực tiếp token của bên thứ ba. Sau khi xác thực thành công, Dịch vụ Xác thực sẽ tạo ra một **JWT nội bộ riêng của KBM** — các dịch vụ xử lý phía sau hoàn toàn không cần biết người dùng đã đăng nhập bằng Microsoft, Google, hệ thống Quản lý Đào tạo hay qua mật khẩu

truyền thống. Mô hình này được gọi là hoán đổi token (token exchange): chuyển đổi từ token bên ngoài sang token nội bộ.

9.4.2. Nhiều phương thức xác thực

KBM hỗ trợ nhiều phương thức xác thực nhưng hội tụ về cùng một token nội bộ:

Phương thức	Luồng	Khi nào
Username/Password	Truyền thống, hash bcrypt	Mặc định cho mọi người dùng
Microsoft/Google OAuth2/OIDC	Authorization Code Flow + PKCE (kèm state chống CSRF và nonce chống replay ID Token) khi phù hợp	SSO bằng tài khoản trường
Cổng QLĐT (Quản lý Đào tạo)	Tích hợp tùy biến	Đăng nhập bằng tài khoản quản lý đào tạo
Xác thực email	Xác thực email trước khi kích hoạt/khôi phục	Giảm tài khoản giả, hỗ trợ cấp lại mật khẩu
Turnstile	Challenge chống bot ở form nhạy cảm	Bảo vệ login/register/reset khỏi các công cụ tự động

Bảng 9.5: Các phương thức xác thực trong KBM

Tất cả các phương thức này đều hội tụ về một đầu ra duy nhất: **KBM JWT token** (chứa `userId`, `roles`, và `expiry`). Auth Service cung cấp hàm `generateTokens(user)` — tiếp nhận đối tượng người dùng từ bất kỳ phương thức đăng nhập nào và trả về cặp `{accessToken, refreshToken}`. Các dịch vụ ở tuyến sau (downstream services) không cần phân biệt nguồn gốc xác thực. Đây là nền tảng cho cơ chế Đăng nhập một lần (SSO) đa nền tảng: các module LMS core, Network Lab và DevOps Lab có thể chia sẻ identity nội bộ mà không buộc từng module hiểu mọi provider bên ngoài.

9.4.3. Service-to-Service: Client Credentials Flow

Lưu ý: Luồng Authorization Code dành cho tương tác có mặt người dùng (User-facing). Khi một dịch vụ chạy nền tự gọi dịch vụ khác (Machine-to-Machine, ví dụ Job Scheduler gọi Judge Service), nó sử dụng **Client Credentials Flow** với credential riêng để nhận access token. Token này nhận diện workload/actor và các scope được cấp cho workload; nó *không được* tự mang user subject. Nếu tác vụ thực sự thực hiện thay mặt người dùng, hệ thống cần một cơ chế delegation hoặc token exchange ghi rõ cả subject lẫn actor, đúng audience của service đích và có thời hạn ngắn.

9.4.4. Không có trình duyệt: Device Authorization Grant

Cả hai luồng trên đều giả định một điều kiện mà không phải client nào cũng có: khả năng mở trình duyệt và nhận redirect. Một công cụ dòng lệnh cho quản trị viên, một script chạy trên máy chủ không giao diện, hay một ứng dụng trên thiết bị chỉ có bàn phím số — không thứ nào làm được điều đó, nhưng vẫn cần đăng nhập *với tư cách một người dùng cụ thể* chứ không phải với tư cách một service.

Device Authorization Grant (RFC 8628) tách đôi quá trình: thiết bị không có trình duyệt hiển thị một mã ngắn kèm một URL; người dùng mở URL đó trên *thiết bị khác* (điện thoại, máy tính), đăng nhập và nhập mã để chấp thuận; trong lúc đó thiết bị ban đầu hỏi vòng (poll) authorization server cho tới khi nhận được token. Nhờ vậy thông tin đăng nhập không bao giờ đi qua thiết bị hạn chế.

Điểm cần nhớ khi chọn luồng: câu hỏi quyết định không phải “client thuộc loại nào” mà là hai câu — *có người dùng thật đúng sau không?* và *client có mở được trình duyệt không?* Có người dùng và có trình duyệt thì dùng Authorization Code (kèm PKCE nếu là client công khai); có người dùng nhưng không có trình duyệt thì dùng Device Authorization Grant; không có người dùng nào cả thì đó là Client Credentials.

9.5. RBAC — Role-Based Access Control

Phân quyền giống như việc cấp thẻ từ cho các khu vực khác nhau trong trường: thẻ của sinh viên chỉ mở được cửa thư viện và giảng đường, trong khi thẻ của giảng viên có thể mở thêm được cửa phòng thí nghiệm chuyên sâu. Việc quản lý truy cập theo vai trò giúp hệ thống dễ dàng kiểm soát ai được phép làm gì.

Trong phép so sánh này, xác thực (Authentication — AuthN) là trình thẻ để chứng minh “Tôi là sinh viên Nguyễn Văn A”; phân quyền (Authorization — AuthZ) là ổ khóa điện tử kiểm tra xem thẻ của Nguyễn Văn A có chữ `GIANG_VIEN` để được phép mở cửa Phòng thí nghiệm Giảng viên hay không.

9.5.1. Vấn đề: ai được làm gì?

Authentication trả lời “người dùng là ai?”. Authorization trả lời “người dùng được làm gì?”. Trong KBM, ba vai trò chính cần các quyền (permissions) khác nhau:

Tại KBM, hệ thống phân quyền được xây dựng trên cơ sở ba cấp bậc rõ ràng. Ở cấp độ thấp nhất, **STUDENT** (Sinh viên) chỉ được cấp các quyền cơ bản như nộp bài, xem kết quả và tham gia kỳ thi. Vai trò **LECTURER** (Giảng viên) kế thừa toàn bộ quyền của sinh viên, đồng thời được trao thêm khả năng tạo lập bài tập, khởi tạo kỳ thi và xem các báo cáo thống kê. Cuối cùng, **ADMIN** có quyền cao nhất, bao gồm toàn bộ quyền của giảng viên và quyền quản lý tài khoản, cấu hình hệ thống.

9.5.2. Triển khai RBAC trong KBM

KBM dùng Spring Security `@PreAuthorize` annotation với roles lưu trong JWT:

```
// Spring Security @PreAuthorize — declarative RBAC
@PreAuthorize("isAuthenticated()")
@GetMapping("/questions")
public List<QuestionResponse> getQuestions() { ... } // Mọi user authenticated

@PreAuthorize("hasAnyRole('LECTURER', 'ADMIN')")
@PostMapping("/questions")
public QuestionResponse create(@RequestBody CreateQuestionRequest r) { ... }

@PreAuthorize("hasRole('ADMIN')")
@DeleteMapping("/questions/{id}")
public void delete(@PathVariable UUID id) { ... }
```

Listing 9.2: Spring Security `@PreAuthorize` — RBAC dạng khai báo (declarative)

Kiểm tra vai trò (role check) chỉ là lớp đầu của local authorization. Với tài nguyên có quan hệ sở hữu (ownership) — chẳng hạn đề thi thuộc lớp nào, giảng viên có phụ trách lớp đó không, sinh viên có ghi danh hay không — service phải kiểm tra quan hệ với chính resource sau khi đã xác minh signed identity proof. Gateway không có đủ domain context để quyết định thay service.

Phân cấp vai trò (role hierarchy): Sơ đồ dưới đây minh họa sự kế thừa quyền hạn giữa các vai trò:



Hình 9.7: Phân cấp vai trò — ADMIN kế thừa LECTURER, LECTURER kế thừa STUDENT

Để áp dụng hệ thống phân cấp này vào mã nguồn, chúng ta có thể cấu hình trực tiếp thông qua Spring Security.

Để cấu hình `RoleHierarchy` trong Spring Security và tránh phải kiểm tra cứng nhiều vai trò, chúng ta khai báo một `@Bean` :

```

@Bean
public RoleHierarchy roleHierarchy() {
    RoleHierarchyImpl r = new RoleHierarchyImpl();
    r.setHierarchy("ROLE_ADMIN > ROLE_LECTURER\nROLE_LECTURER > ROLE_STUDENT");
    return r;
}
  
```

Chi tiết về cấu hình OAuth2 Client với Google/Entra ID được cung cấp đầy đủ trong source code Companion Repo.

Trong hiện trạng, KBM lưu roles dạng **pipe-delimited** trong JWT: `"ADMIN|LECTURER|STUDENT"`; Gateway còn dẫn xuất `X-User-Roles` và Core Service phân tích chuỗi này. Ở mô hình mục tiêu, service lấy roles/permissions từ token hoặc metadata có chữ ký đã được xác minh; header dẫn xuất chỉ là context, không phải nguồn quyền độc lập.

9.5.3. Bảo vệ route dựa trên API (Frontend)

Frontend của KBM sử dụng một pattern khác: **route permissions được truy xuất động từ API** (`GET /api/auth/me/permissions`) thay vì gán cứng (hardcoded) — response chứa danh sách route và action mà người dùng được phép. Frontend hiển thị động (dynamic render) các route dựa trên phân quyền này. Ưu điểm lớn nhất là khi có thay đổi về phân quyền ở phía máy chủ (backend), giao diện máy khách sẽ tự động cập nhật cấu trúc mà không cần phải trải qua quá trình triển khai (deploy) lại.

i RBAC trong KBM

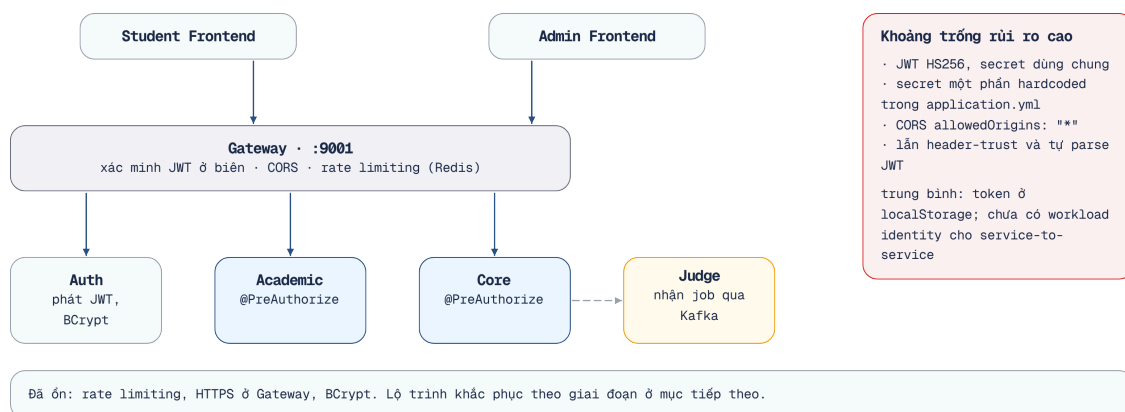
Cách thức triển khai của KBM hiện tại còn một số hạn chế: (1) Các vai trò (roles) được lưu dưới dạng chuỗi phân tách bằng dấu gạch đứng (pipe-delimited string) thay vì cấu trúc mảng. Điều này bắt buộc hệ thống phải phân tích cú pháp một cách thủ công, dễ phát sinh lỗi nếu tên vai trò có chứa ký tự phân cách. (2) Các chú thích `@PreAuthorize` nằm rải rác ở từng controller — gây khó khăn cho quá trình kiểm toán (audit) quyền hạn của một vai trò cụ thể trên toàn bộ các endpoint. (3) KBM đang thiếu một hệ thống phân cấp vai trò (role hierarchy) rõ ràng ở tầng Spring Security — dẫn đến việc vai trò ADMIN phải liệt kê lại toàn bộ các quyền của LECTURER và STUDENT. (4) Phân hệ DevOps Lab cần bổ sung các chính sách kiểm soát tại tầng thực thi (runtime layer) để xác định rõ người dùng nào được phép khởi tạo không gian làm việc, vùng mạng cách ly, container hoặc các công việc đòi hỏi đặc quyền cao.

Lộ trình chuyển đổi (Migration path): (1) chuyển đổi cấu trúc lưu trữ vai trò sang mảng JSON (JSON array) bên trong JWT payload, (2) thiết lập cấu hình `RoleHierarchy` thống nhất trong Spring Security, và (3) cân nhắc việc quy tụ các chính sách phân quyền về một nền tảng quản lý tập trung (như Spring Security method security hoặc Open Policy Agent).

9.6. Case Study: KBM

Phần này tổng hợp đánh giá tổng thể kiến trúc bảo mật của KBM, nhận diện các lỗ hổng tiềm ẩn (gap analysis) và đề xuất lộ trình khắc phục (migration roadmap) theo từng giai đoạn.

Tổng quan



Hình 9.8: Kiến trúc bảo mật tổng thể của KBM

9.6.1. Phân tích tổng hợp

Việc đánh giá chi tiết kiến trúc bảo mật của KBM giúp nhận diện những lỗ hổng tiềm ẩn (tương tự như công tác thanh tra giáo dục đối với quy trình tổ chức thi). Bảng dưới đây tổng hợp các khía cạnh bảo mật, rủi ro tương ứng và đề xuất biện pháp phòng ngừa:

Khía cạnh	Hiện trạng	Mức rủi ro	Giải pháp khuyến nghị
Thuật toán JWT	HS256 (symmetric, shared secret)	● Cao	RS256 + JWKS; chỉ issuer giữ private key
Lưu trữ token	Client-side (localStorage)	! Trung bình	HttpOnly cookie (chống XSS)

Khía cạnh	Hiện trạng	Mức rủi ro	Giải pháp khuyến nghị
Secret Management	Một phần hardcoded trong application.yml, một phần qua biến môi trường	● Cao	Vault, AWS Secrets Manager
CORS	<code>allowedOrigins: ""</code>	● Cao	Chỉ cho phép các origin cụ thể
Identity propagation	Lỗi header-trust và bespoke JWT parsing	● Cao	Signed proof đúng audience + local authorization
Service-to-service auth	Chưa có workload identity thống nhất	! Trung bình	Workload token/ mTLS; delegation khi có user subject
Rate Limiting	Đã có (Redis-based)	✓ Thấp	Tinh chỉnh chính sách cho kỳ thi
Xác thực email / Chống bot	Có/đang hoàn thiện theo module	! Trung bình	Xác thực email + Turnstile cho form nhạy cảm
Cô lập DevOps Lab	Runtime isolation riêng	● Cao nếu cấu hình sai	Sysbox/k3s + NetworkPolicy/RBAC
Xác thực dữ liệu đầu vào	Một phần	! Trung bình	Sử dụng Bean Validation (<code>@Valid</code>)
HTTPS	Gateway level	✓ Thấp	—
Băm mật khẩu	BCrypt	✓ Thấp	—

Bảng 9.6: Phân tích bảo mật KBM

Trong các thuật toán ở bảng trên, HS256 là chỗ dễ cấu hình sai nhất — ràng buộc về độ dài khóa thường bị bỏ qua.

⚠ Độ dài khóa HS256

Với thuật toán HS256, giá trị của `jwt.secretKey` bắt buộc phải là một chuỗi ngẫu nhiên có độ dài tối thiểu 256 bits (32 bytes). Các thư viện JWT hiện đại (như `jjwt` bản mới) sẽ ném ra (throw) `WeakKeyException` lúc khởi động nếu khóa quá ngắn.

9.6.2. Đề xuất migration

Giai đoạn 1 — Các cải tiến nhanh (Quick Wins) (giải pháp ngắn hạn tối ưu: nỗ lực thực hiện thấp nhưng mang lại hiệu quả cao):

- Giới hạn nguồn gốc CORS (Restrict CORS origins) (Lưu ý: Nếu kích hoạt HttpOnly cookie (kéo theo `allowCredentials=true`), hệ thống tuyệt đối không được sử dụng `allowedOrigins("")` — đặc tả CORS buộc trình duyệt chặn (block) tổ hợp wildcard + credentials, đây là quy tắc bảo mật, không phải vấn đề tương thích).
- Di chuyển các thông tin nhạy cảm (secrets) ra khỏi application.yml → biến môi trường (tối thiểu).
- Lưu trữ token trong HttpOnly cookie thay vì localStorage.

- Kích hoạt xác thực email và Turnstile cho login/register/reset ở các luồng giao tiếp công khai (public flows).
- Gỡ bỏ mọi `X-User-*` từ ingress, giữ signed proof cho downstream và xác minh cấu hình chặn truy cập trực tiếp tới service.
- Chuẩn hóa ngay hợp đồng xác minh: allowed algorithm, issuer, audience, `exp`, `nbf`; không để mỗi service tự chọn quy tắc.

Giai đoạn 2 — Tăng cường Xác thực (Authentication Hardening) (nỗ lực triển khai trung bình):

- Chuyển đổi thuật toán ký từ HS256 sang RS256 và công bố public keys qua JWKS
- Dùng Spring Security OAuth2 Resource Server hoặc middleware tương đương tại Gateway và resource services
- Triển khai luồng làm mới token kết hợp luân phiên khóa (mỗi lần làm mới sẽ vô hiệu hóa token cũ)
- Chuẩn hóa SSO theo token exchange: token nội bộ có issuer/audience rõ ràng và hợp đồng claims chung

Giai đoạn 3 — Workload Identity và Delegation (nỗ lực triển khai cao, áp dụng khi mở rộng quy mô):

- Xác thực service-to-service bằng workload token và/hoặc mTLS
- Tách subject khỏi actor; chỉ cho phép on-behalf-of khi có delegation rõ ràng, đúng audience và thời hạn ngắn
- Với job bất đồng bộ, ký hoặc ràng buộc command context để consumer xác minh quyền thực thi (Tier 3)
- Quản lý secret tập trung (HashiCorp Vault)
- Chính sách phân quyền ở mức API (Open Policy Agent)
- Rào chắn runtime cho DevOps Lab: Kubernetes RBAC, NetworkPolicy, resource quotas và Sysbox isolation

9.6.3. Secret Management trong Production

9.6 cho thấy “Quản lý Thông tin Bí mật (Secret Management)” ở mức độ rủi ro ● Cao (High) — `jwt.secretKey` bị gán cứng (hardcoded) trong `application.yml` và được lưu trữ (commit) trực tiếp vào Git. Đây là lỗi hỏng phổ biến nhất trong microservices và cần được khắc phục ở mọi hệ thống thực tế (production).

Ba cấp độ Secret Management:

Cấp độ	Cách tiếp cận	Ưu điểm	Nhược điểm	Phù hợp
Cấp 1	Biến môi trường (Environment Variables)	Đơn giản, tách secret khỏi code	Secrets ở dạng văn bản thô trên server, không có nhật ký kiểm toán (audit trail)	Dev/Staging
Cấp 2	Cấu hình mã hóa (Encrypted Config: Spring Cloud Config + Jasypt)	Secrets mã hóa trong repo, giải mã lúc runtime	Vẫn cần quản lý khóa mã hóa	Production quy mô nhỏ

Cấp độ	Cách tiếp cận	Ưu điểm	Nhược điểm	Phù hợp
Cấp 3	Secret Manager (HashiCorp Vault, AWS Secrets Manager, GCP Secret Manager)	Tự động xoay vòng, nhật ký kiểm toán, chính sách truy cập, dynamic secrets	Chi phí hạ tầng, độ phức tạp vận hành	Production quy mô lớn

Bảng 9.7: Chiến lược Secret Management — từ cơ bản đến quy mô doanh nghiệp

Cấp 1 — Biến môi trường (LMS nên áp dụng ngay):

Thay vì:

```
# SAI: application.yml — KHÔNG BAO GIỜ lưu trữ (commit) thông tin nhạy cảm
jwt:
  secretKey: "mySecretKey123"
  expiration: 86400000
```

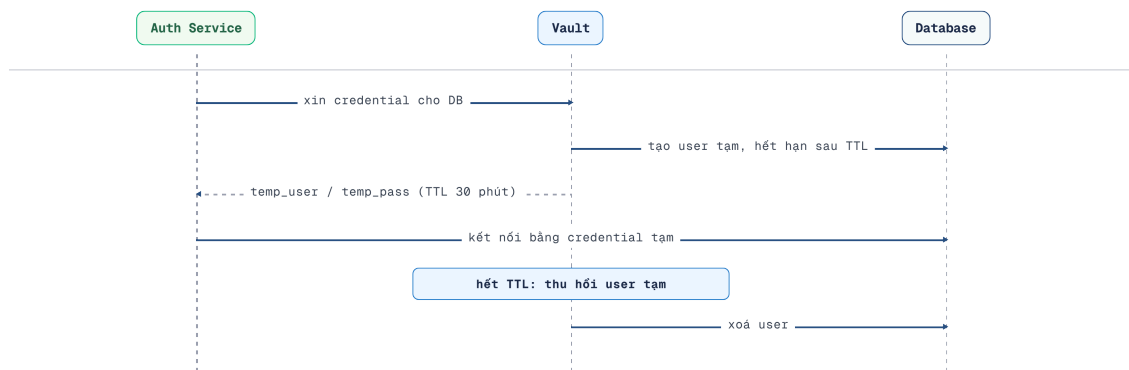
Sử dụng:

```
# ĐÚNG: application.yml — reference environment variable
jwt:
  secretKey: ${JWT_SECRET_KEY}
  expiration: ${JWT_EXPIRATION:86400000}
```

```
# Docker Compose — inject từ .env file (không commit .env)
services:
  kbm-auth:
    environment:
      - JWT_SECRET_KEY=${JWT_SECRET_KEY}
      - DB_PASSWORD=${DB_PASSWORD}
```

Cấp 3 — HashiCorp Vault (khi hệ thống production hoàn chỉnh):

Vault cung cấp **dynamic secrets** — database credentials được tạo tự động, có thời hạn, và tự động xoay vòng (auto-rotate). Không ai biết mật khẩu database thực sự — kể cả lập trình viên.



Được: không ai biết mật khẩu database thật; credential tự hết hạn và xoay vòng; mọi lần cấp đều có audit.
Trả giá: thêm một hệ thống phải vận hành và giữ sẵn sàng. Đây là Cấp 3, khi production hoàn chỉnh — hiện KBM để secret một phần hardcoded, một phần qua biến môi trường.

Hình 9.9: Vault Dynamic Secrets — thông tin xác thực tạm thời, tự động xoay vòng

Bước đầu tiên và quan trọng nhất là thêm `.env` vào `.gitignore`, đồng thời tạo `.env.example` không chứa giá trị thực để các thành viên trong nhóm phát triển biết những biến cần thiết lập. Đây là một ‘cải tiến bảo mật không tốn chi phí’ (zero-cost security improvement) mà mọi dự án đều nên áp dụng ngay lập tức. Một số lỗi hỏng bảo mật thường gặp ở mức mã nguồn và cấu hình dịch vụ:

⚠ Mã nguồn và cấu hình

Lưu JWT trong localStorage

Bất kỳ đoạn mã JavaScript nào chạy trên trang cũng đều có thể đọc được dữ liệu này (tấn công XSS). Hậu quả: nếu tồn tại lỗ hổng XSS, kẻ tấn công có thể đánh cắp token và từ đó mạo danh người dùng.

Phòng tránh: lưu trữ JWT trong HttpOnly cookie (JavaScript không đọc được), kết hợp `Secure`, `SameSite=Lax/Strict` và CSRF token hoặc kiểm tra Origin cho các yêu cầu thay đổi trạng thái — vì trình duyệt tự động đính kèm cookie, HttpOnly chỉ bảo vệ tính bí mật của token chứ không tự ngăn được tấn công CSRF.

Hardcode secrets trong source code

`jwt.secretKey=mySecretKey123` trong `application.yml`, commit vào Git. Hậu quả: ai có quyền truy cập repo đều có thể tạo JWT giả mạo. **Phòng tránh:** dùng biến môi trường (tối thiểu), hoặc secret manager (Vault, AWS Secrets Manager).

Không đặt thời hạn (expiry) cho JWT

Token không bao giờ hết hạn. Hậu quả: nếu token bị rò rỉ, kẻ gian sẽ có quyền truy cập vĩnh viễn và hệ thống không có cách nào để thu hồi. **Phòng tránh:** dùng access token ngắn hạn (15–60 phút), kết hợp refresh token có thời hạn dài hơn (7–30 ngày) đi kèm cơ chế luân phiên (rotation).

Xác thực JWT ở mỗi dịch vụ bằng cách khác nhau

Mỗi dịch vụ sử dụng một phiên bản thư viện JWT và tập quy tắc riêng. Hậu quả không chỉ là Gateway chấp nhận nhưng service từ chối; một verifier lỏng hơn còn có thể chấp nhận sai thuật toán, issuer hoặc audience. **Phòng tránh:** chuẩn hóa resource verification bằng cùng framework, issuer metadata/JWKS và test contract. Gateway kiểm tra ở ingress; service đích vẫn xác minh signed proof và local authorization (§9.3).

Confused Deputy Problem

Dịch vụ A gọi Dịch vụ B thay mặt người dùng, nhưng B không biết A đang “đại diện” cho người dùng hay hành động với đặc quyền riêng của A. Newman trong [4a, Ch.9] gọi đây là **confused deputy attack**. Hậu quả: người dùng chỉ có quyền STUDENT nhưng A lại gọi B bằng credential hệ thống toàn quyền.

Phòng tránh: proof on-behalf-of phải tách user *subject* khỏi calling *actor/workload*, ghi rõ delegation, audience và thời hạn. B xác minh proof rồi giới hạn quyền theo cả subject lẫn actor; plain `X-User-*` không đủ để biểu diễn quan hệ này.

Các kỹ sư có thể tự trải nghiệm những cuộc tấn công này qua mô phỏng tương tác:

💡 Interactive Demo

Xem minh họa động tại companion web:

Luồng xác thực OAuth2 & JWT – — oauth2-jwt-flow.html

Role-Based Access Control (RBAC) – — rbac-authorization.html

⚠ Sai lầm thường gặp**Dùng HS256 shared secret cho production**

Tất cả các dịch vụ chia sẻ chung một khóa bí mật để ký và xác thực JWT. Hậu quả: nếu chỉ một dịch vụ bị xâm nhập, kẻ tấn công có thể tạo token giả mạo cho bất kỳ người dùng nào trên toàn hệ thống.

Phòng tránh: chuyển sang sử dụng thuật toán bất đối xứng RS256/JWKS — theo đó, chỉ duy nhất Dịch vụ Xác thực mới được giữ khóa riêng tư (private key) để ký, còn các dịch vụ khác chỉ sử dụng khóa công khai (public key) để tiến hành xác minh.

Tin tưởng dữ liệu định danh do client gửi

Đọc thẳng header như `X-User-Id` hoặc tin claim chỉ vì nó đi qua mạng nội bộ. Hậu quả: leo thang đặc quyền và confused deputy. **Phòng tránh:** Gateway gỡ bỏ identity headers từ client; signed proof phải được service đích kiểm tra chữ ký, issuer, audience và freshness trước khi authorize. Header dẫn xuất không được trở thành nguồn quyền độc lập.

Token sống quá lâu, không thể thu hồi

Access token có thời hạn quá dài, không đi kèm cơ chế làm mới hoặc luân phiên. Hậu quả: token bị lộ vẫn có thể được sử dụng trong thời gian dài mà không thể thu hồi. **Phòng tránh:** kết hợp access token ngắn hạn với cơ chế luân phiên refresh token, đồng thời giám sát để phát hiện tái sử dụng trái phép (vô hiệu hóa toàn bộ chuỗi token).

Hardcode secret trong source/application.yml

Lưu secret, key, mật khẩu DB trực tiếp trong file cấu hình commit lên Git. Hậu quả: rò rỉ secret qua lịch sử Git. **Phòng tránh:** dùng biến môi trường / secret manager (Vault), không commit secret.

9.7. Cô lập thực thi và phong tỏa (lockdown) thi cử — Hai bài học phòng thủ

Bảo mật không dừng ở JWT và RBAC. Hai nghiệp vụ chấm code và thi phòng máy của KBM cho thấy hai mặt khác của phòng thủ: **cô lập tài nguyên** khi phải chạy mã không tin cậy, và **phòng thủ chiều sâu** khi chống gian lận.

9.7.1. Chạy mã sinh viên: rủi ro “no sandbox” và lời giải cô lập

Bộ chấm code thế hệ đầu (`kbm-judge-code` Gen 1) chạy bài nộp C/C++ và Java **trực tiếp trong tiến trình máy chủ, không có sandbox**. Đây là lỗ hổng nghiêm trọng: mã sinh viên là *dữ liệu đầu vào không đáng tin cậy có khả năng thực thi* — nó có thể đọc/ghi file hệ thống, thiết lập kết nối mạng trái phép ra bên ngoài, tiêu thụ vô hạn CPU/RAM, hoặc cố ý gây ngưng trệ dịch vụ. Khác với chấm SQL (chạy trong sandbox CSDL cô lập mỗi lần nộp bài) hay lab DevOps (pod Sysbox cô lập), judge code Gen 1 bỏ qua hoàn toàn lớp cô lập — một dạng đánh đổi “tự viết để kiểm soát tối đa” nhưng vô tình mở rộng bề mặt tấn công ngay bên trong ranh giới tin cậy của dịch vụ.

⚠ Không bao giờ chạy mã không tin cậy (untrusted code) chung tiến trình

Mã do người dùng nộp lên (judge code, plugin, công thức tùy biến...) phải được xem như **thù địch cho đến khi được chứng minh ngược lại**. Chạy nó chung tiến trình/máy chủ với service đồng nghĩa trao cho kẻ tấn công chính quyền hạn của service đó: truy cập file, mạng, secret trong biến môi trường, và tài nguyên không giới hạn. Lỗ hổng này không phải lỗi logic — nó là *thiếu vắng một lớp cô lập*.

Thế hệ hiện tại tích hợp **DOMjudge**, chạy mỗi bài nộp trong **sandbox cô lập** dựa trên cgroup/namespace của Linux: giới hạn CPU, bộ nhớ, thời gian thực thi, và cắt quyền truy cập tài nguyên ngoài. Nguyên tắc bảo mật cốt lõi: **không bao giờ chạy mã không tin cậy trong cùng ranh giới tin cậy (trust boundary) với dịch vụ**. Ở đây, cô lập (sandbox) đi song hành với quyết định tự xây dựng hay mua sẵn (build-vs-buy) (Chương 3, Chương 4). Việc lựa chọn một hệ thống chấm điểm mã nguồn mở (OSS judge) đã được kiểm chứng qua hàng nghìn kỳ thi vừa giải quyết bài toán đa ngôn ngữ, vừa khắc phục hoàn toàn lỗ hổng thiếu cô lập mà phiên bản tự phát triển trước đó gặp phải.

9.7.2. Phong tỏa thi cử và phòng thủ chiều sâu chống gian lận

Với kỳ thi tại phòng máy, KBM dùng **kbm-exam-client** — một desktop client siết môi trường thi: bắt buộc toàn màn hình, chặn Alt-Tab/chuyển ứng dụng, vô hiệu copy-paste và chuột phải, chặn mở trình duyệt/tài liệu ngoài, và chỉ cho kết nối từ **danh sách IP được phép (IP whitelist)** của phòng thi. Client còn thu tín hiệu giám sát (rời cửa sổ, mất focus, cắm/rút thiết bị) và đẩy về server làm dữ liệu chống gian lận (anti-cheat). Client này dùng cùng JWT của **kbm-auth** (SSO) và là một client của bounded context Examination & Proctoring.

Tuy nhiên, việc phong tỏa (lockdown) ở phía máy khách **không bao giờ được coi là lớp phòng thủ duy nhất**. Một thí sinh có kỹ thuật hoàn toàn có thể vá, giả lập, hoặc đơn giản là bỏ qua client desktop — mọi thứ chạy trên máy người dùng đều nằm dưới quyền kiểm soát của người dùng. Vì vậy server (logic Contest/Anti-cheat, hiện trong **kbm-core**) phải **độc lập** phát hiện bất thường: đổi IP hoặc User-Agent giữa ca thi, tần suất nộp bài bất thường, số lần vi phạm vượt ngưỡng cấu hình. Đây chính là **phòng thủ chiều sâu** (§9.1) áp dụng cho anti-cheat: tín hiệu được thu cả ở client (lockdown) lẫn ở server (phát hiện bất thường), không phía nào là điểm tin cậy tuyệt đối.

Lockdown của **kbm-exam-client** chỉ làm *tăng chi phí gian lận*, không *loại bỏ* khả năng gian lận. Tương tự như nguyên lý khi Gateway gỡ bỏ header **X-User*** từ Internet (§9.3), mọi tín hiệu bảo mật do client gửi lên đều phải được server kiểm chứng hoặc đối chiếu độc lập. Máy khách đảm nhiệm trải nghiệm người dùng và là lớp ngăn chặn đầu tiên; máy chủ nắm quyền quyết định cuối cùng và là căn cứ tin cậy duy nhất cho anti-cheat.

9.8. Tổng kết

Bảo mật microservices phức tạp hơn hệ thống nguyên khối (monolith) vì bề mặt tấn công (attack surface) lớn hơn — mỗi dịch vụ, mỗi cuộc gọi mạng (network call), mỗi cơ sở dữ liệu đều là điểm tiềm ẩn rủi ro. Defense in depth — phòng thủ chiều sâu, bảo vệ nhiều lớp thay vì dựa vào một lớp duy nhất — là nguyên tắc nền tảng.

JWT cung cấp signed claims (thông tin định danh có chữ ký số) theo cách phi trạng thái (stateless), không cần một session store chung cho mỗi request. HS256 (ký bằng khóa đối xứng) đơn giản nhưng mọi verifier (bên xác minh) giữ shared secret cũng có khả năng tự ký token — chỉ nên dùng trong phạm vi hẹp và được kiểm soát chặt. RS256 (ký bằng cặp khóa bất đối xứng) tách signer khỏi verifier: Auth Service giữ private key, còn resource services lấy public keys qua JWKS (endpoint cung cấp khóa công khai). Dù dùng thuật toán nào, verifier vẫn phải khóa thuật toán, issuer, audience và freshness (thời hạn token).

Tiered Trust (mô hình tin cậy phân tầng) tách ba lớp kiểm tra: edge validation (Gateway xác thực token ở biên), resource verification (service đích kiểm tra chữ ký và quyền truy cập) và DB-based state check (đối chiếu trạng thái tại cơ sở dữ liệu). Tier 1 yêu cầu signed proof (bằng chứng có chữ ký) cùng local authorization (phân quyền tại service sở hữu nghiệp vụ); Tier 2 bổ sung workload identity, actor và delegation (ủy quyền); Tier 3 bảo vệ command bất đồng bộ. NetworkPolicy và mTLS thu hẹp đường đi mạng, nhưng không thay thế bằng chứng cho user subject (danh tính người dùng). OAuth2/OIDC cho

phép giao việc xác thực người dùng cho identity provider chuyên dụng; Client Credentials chỉ đại diện workload (dịch vụ gọi dịch vụ) nếu không có delegation rõ ràng.

RBAC (phân quyền theo vai trò) là điểm khởi đầu phổ biến cho authorization. KBM triển khai RBAC qua `@PreAuthorize`, nhưng role check phải đi cùng kiểm tra ownership (ai sở hữu tài nguyên?) và quan hệ với resource tại service đích — ví dụ, sinh viên chỉ xem được bài nộp của chính mình dù cùng role `STUDENT`.

Hệ thống hiện còn thiếu role hierarchy rõ ràng và một bề mặt chính sách (policy surface) để kiểm toán.

Phân tích KBM cho thấy hệ thống đã có JWT, Gateway, RBAC và SSO, nhưng identity propagation hiện vẫn là accepted risk: HS256 shared secret, plain-header trust và bespoke parsing cùng tồn tại, trong khi bằng chứng về việc thực thi chính sách mạng chưa hoàn chỉnh. Lộ trình mục tiêu là làm sạch request ở biên, thống nhất hợp đồng xác minh, chuyển sang RS256/JWKS cùng signed downstream identity, rồi bổ sung workload identity/delegation theo trust tier. Các khoản nợ khác — CORS, secret management, token storage và runtime isolation — vẫn phải được xử lý song song.

Ở Chương 10, chúng ta sẽ tổng hợp mọi kiến thức từ Chương 1-9 vào **bài toán thực tế nhất**: chuyển đổi từ monolith sang microservices — khi nào nên chuyển, Strangler Fig pattern, tách database, và lộ trình chuyển đổi cho KBM.

9.9. Đọc thêm

Sách tham khảo chính:

1. [4a] Sam Newman, *Building Microservices* — Ch.9: Security
2. [2a] Chris Richardson, *Microservices Patterns*, 1st Ed. — Ch.11: Developing secure services, Access Token pattern
3. [7] Martin Kleppmann, *Designing Data-Intensive Applications* — Ch.4: Encoding and Evolution (data formats, schema evolution — nền tảng cho hiểu binary/JSON encoding trong tokens và API messages)

Nguồn trực tuyến:

- JWT.io — jwt.io (interactive JWT decoder)
- OWASP API Security Top 10 — owasp.org/www-project-api-security
- Spring Security OAuth2 Resource Server — docs.spring.io/spring-security
- RFC 7519 — JSON Web Token (JWT) specification
- NIST SP 800-207 — Zero Trust Architecture
- RFC 8725 — JSON Web Token Best Current Practices
- RFC 9068 — JWT Profile for OAuth 2.0 Access Tokens
- RFC 9700 — Best Current Practice for OAuth 2.0 Security

Bài tập: Xem Phụ lục Bài tập để luyện tập:

9-0 – Ôn tập: Authentication vs Authorization ([L1])

9-1 – Sự cố bảo mật: Đánh cắp JWT token (Debugging [L3])

9-2 – OAuth2 + OIDC Flows — Chọn flow nào cho kịch bản nào? (Trade-off Analysis [L2])

Tài liệu tham khảo

- Newman, S. (2015). *Building Microservices*, Chapter 9: Security. O'Reilly Media.